

УТВЕРЖДЕНО
приказом [НАИМЕНОВАНИЕ ОПЕРАТОРА]
от «___» _____ 20__ г. № ____

_____/_____
подпись Ф.И.О.

РЕГЛАМЕНТ

обработки и защиты персональных данных

[НАИМЕНОВАНИЕ ОПЕРАТОРА]

СТАТУС ДОКУМЕНТА

Внутренний локальный акт. Версия 1.0. Вводится в действие приказом руководителя. Поля в квадратных скобках заполняются до утверждения.

Владелец документа	Ответственный за организацию обработки персональных данных
Дата актуализации	22 сентября 2026 года
Период пересмотра	Не реже одного раза в год и при изменении процессов или законодательства

→ Навигация по регламенту

1. Общие положения
 2. Принципы и правовые основания
 3. Цели, субъекты и состав данных
 4. Сбор персональных данных и согласие
 5. Порядок обработки и доступа
 6. Передача, поручение и трансграничная передача
 7. Права субъекта и обработка обращений
 8. Безопасность и реагирование на инциденты
 9. Хранение, блокирование и уничтожение
 10. Контроль, обучение и ответственность
 11. Заключительные положения
- Приложения: матрица ролей, сроки, формы журналов и актов

КАК ПРИМЕНЯТЬ

Регламент задает единый обязательный порядок. Для каждого фактического процесса Оператор ведет реестр целей обработки, определяет правовое основание, минимальный набор данных, срок хранения, получателей, информационные системы и ответственных лиц.

Карточка Оператора

Параметр	Сведения
Полное наименование	[ПОЛНОЕ НАИМЕНОВАНИЕ]
ИНН / ОГРН	[ИНН] / [ОГРН]
Адрес	[ЮРИДИЧЕСКИЙ И ПОЧТОВЫЙ АДРЕС]
Контакт по вопросам ПДн	[Ф.И.О., ДОЛЖНОСТЬ, E-MAIL, ТЕЛЕФОН]
Сайт и страница политики	[ДОМЕН] / [ССЫЛКА НА ПОЛИТИКУ]
Запись в реестре операторов	[НОМЕР И ДАТА, ЕСЛИ ПРИМЕНИМО]

→ 1. Общие положения

1.1. Настоящий Регламент определяет цели, принципы, правовые основания, состав и порядок обработки персональных данных, правила доступа к ним, меры защиты, порядок реагирования на обращения и инциденты, а также обязанности работников [НАИМЕНОВАНИЕ ОПЕРАТОРА] (далее - Оператор).

1.2. Регламент обязателен для работников, стажеров, временного персонала и иных лиц, получивших доступ к персональным данным в связи с выполнением трудовых, договорных или служебных обязанностей. Требования включаются в поручения и договоры с обработчиками в применимой части.

1.3. Регламент применяется к автоматизированной и неавтоматизированной обработке, включая сбор через сайт, формы, электронную почту, мессенджеры, телефон, пропускные системы, бумажные анкеты и договоры.

1.4. Нормативная основа

1.4.1. Конституция Российской Федерации, глава 14 Трудового кодекса Российской Федерации, Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных», Федеральный закон от 27.07.2006 № 149-ФЗ «Об информации, информационных технологиях и о защите информации».

1.4.2. Постановление Правительства РФ от 15.09.2008 № 687 об особенностях неавтоматизированной обработки и постановление Правительства РФ от 01.11.2012 № 1119 о требованиях к защите ПДн в информационных системах.

1.4.3. Приказ ФСТЭК России от 18.02.2013 № 21, приказы Роскомнадзора от 27.10.2022 № 178 и от 28.10.2022 № 179, а также иные применимые акты в действующей редакции.

1.5. Основные термины

Термин	Рабочее определение
Персональные данные (ПДн)	Любая информация, относящаяся к прямо или косвенно определенному или определяемому физическому лицу.
Обработка	Любое действие или совокупность действий с ПДн, включая сбор, запись, хранение, изменение, использование, передачу, блокирование, удаление и уничтожение.
Предоставление / распространение	Раскрытие определенному лицу или кругу лиц / раскрытие неопределенному кругу лиц.
Инцидент	Событие, повлекшее или способное повлечь неправомерную или случайную передачу, предоставление, распространение либо доступ к ПДн.

→ 2. Принципы и правовые основания

2.1. Законность и справедливость. Каждая операция должна иметь заранее определенную цель и подтвержденное правовое основание.

2.2. Ограничение целью. Не допускается обработка, несовместимая с заявленной целью, и объединение баз, созданных для несовместимых целей.

2.3. Минимизация. Состав и объем ПДн должны быть достаточными и не избыточными относительно цели.

2.4. Точность. Оператор принимает разумные меры по актуализации, исправлению или удалению неполных и неточных данных.

2.5. Ограничение хранения. Данные хранятся не дольше, чем этого требует цель, договор, закон или утвержденная номенклатура дел.

2.6. Конфиденциальность и безопасность. Доступ предоставляется по принципам служебной необходимости и минимальных привилегий.

2.7. Подотчетность. Оператор документирует цели, основания, согласия, передачи, обращения, инциденты, проверки и уничтожение.

2.8. Допустимые правовые основания

Основание	Условие применения
Согласие субъекта	Конкретное, предметное, информированное, сознательное и однозначное; факт получения доказуем. С 01.09.2025 оформляется отдельно от иных подписываемых документов.
Закон / полномочие	Обработка необходима для выполнения обязанности или полномочия, прямо установленного законодательством.
Договор с субъектом	Обработка необходима для заключения или исполнения договора, стороной, выгодоприобретателем или поручителем по которому является субъект.
Права и законные интересы	Применяется после документированной проверки баланса интересов и при условии, что права и свободы субъекта не нарушаются.
Иные основания ст. 6, 10, 11 152-ФЗ	Используются только при точном соответствии условиям нормы; специальные и биометрические данные требуют отдельной проверки.

КОНТРОЛЬНАЯ ТОЧКА

До запуска нового процесса владелец процесса направляет ответственному за ПДн описание цели, категорий субъектов и данных, источников, систем, сроков, получателей и правового основания. Обработка начинается только после согласования и внесения в реестр процессов.

→ 3. Цели, субъекты и состав данных

3.1. Конкретные цели и параметры обработки фиксируются в реестре процессов Оператора. Перечень ниже является базовым и подлежит адаптации к фактической деятельности.

Цель	Субъекты	Типовые данные	Основание / срок
Кадровое и бухгалтерское администрирование	Работники, кандидаты, бывшие работники, родственники	Ф.И.О., контакты, документы, образование, стаж, банковские и налоговые реквизиты, сведения о труде	Закон, трудовой договор; сроки по архивному, налоговому и трудовому законодательству
Заключение и исполнение договоров	Клиенты, заказчики, исполнители, представители контрагентов	Ф.И.О., должность, контакты, реквизиты документа, платежные данные в необходимом объеме	Договор, закон; срок договора и срок исковой давности/учета
Коммуникации и поддержка	Пользователи, заявители, посетители сайта	Имя, телефон, e-mail, содержание обращения, технические данные	Согласие, договор или законный интерес; до достижения цели и по утвержденному сроку
Маркетинг	Клиенты и подписчики	Имя, контакты, предпочтения, история взаимодействия	Предварительное согласие; до отзыва или окончания установленного периода
Безопасность и пропускной режим	Работники и посетители	Ф.И.О., данные пропуска, время входа/выхода, изображение с камер при наличии	Законный интерес/локальные правила; минимально необходимый срок

3.2. Ограничения

3.2.1. Запрещается собирать данные «на будущее», требовать необязательные копии документов, использовать свободные текстовые поля без необходимости или сохранять ПДн в личных облаках, личной почте и несанкционированных мессенджерах.

3.2.2. Специальные категории ПДн и биометрические ПДн обрабатываются только при наличии прямо применимого основания, отдельного описания цели и усиленных мер защиты. По умолчанию такие данные не собираются.

3.2.3. ПДн несовершеннолетних обрабатываются с учетом их возраста, интересов и полномочий законного представителя. Объем данных сокращается до строго необходимого.

ОБЯЗАТЕЛЬНО

Фактические сроки хранения утверждаются отдельно: в реестре процессов, номенклатуре дел, графике хранения или ином локальном акте. Формулировка «до утраты необходимости» без критериев и контрольной даты не допускается.

→ 4. Сбор персональных данных и согласие

4.1. При сборе Оператор сообщает субъекту наименование и адрес Оператора, цель, перечень данных, предполагаемых пользователей, способы обработки, срок действия согласия или иной срок обработки, порядок отзыва и иные обязательные сведения.

4.2. Если предоставление данных обязательно по закону, субъекту разъясняются юридические последствия отказа. Если данные получены не от субъекта, до начала обработки предоставляется предусмотренная законом информация, кроме установленных законом исключений.

4.3. Согласие запрашивается только когда отсутствует иное достаточное правовое основание либо когда закон прямо требует согласия. Доказывание наличия согласия или другого основания лежит на Операторе.

4.4. Согласие оформляется отдельно от иной информации и документов, подписываемых или подтверждаемых субъектом. Недопустимы заранее проставленные отметки, неясные цели, объединение несвязанных целей и принуждение к необязательной обработке.

4.5. Согласие на распространение ПДн оформляется отдельно от иных согласий. Молчание или бездействие не признаются согласием. Оператор соблюдает установленные субъектом запреты и условия.

4.6. Согласие регистрируется: субъект, версия текста, дата и время, канал, идентификатор формы, заявленные цели, срок, подтверждение волеизъявления и сведения об отзыве.

4.7. При сборе ПДн граждан Российской Федерации, в том числе через Интернет, запись, систематизация, накопление, хранение, уточнение и извлечение осуществляются с использованием баз данных на территории Российской Федерации, кроме предусмотренных законом случаев.

4.8. Чек-лист электронной формы

Проверка	Требование
Минимизация	Каждое поле связано с целью; необязательные поля явно отмечены.
Информирование	Рядом доступны политика, сведения об Операторе и контакты для обращений.
Согласие	Отдельный текст и отдельное действие; версия и факт согласия журналируются.
Безопасность	TLS, защита от автоматических атак, ограничение журналирования содержимого полей, контроль доступа.
Локализация	Первичная запись и предусмотренные операции выполняются в базе на территории РФ.

→ 5. Порядок обработки и доступа

5.1. Доступ предоставляется на основании роли, служебной необходимости и распоряжения уполномоченного руководителя. Перечень допущенных лиц и права доступа пересматриваются не реже одного раза в год, а также при переводе или увольнении.

5.2. Работник использует ПДн только в пределах порученной цели, соблюдает конфиденциальность, не передает учетные данные и незамедлительно сообщает о подозрительном событии.

5.3. В информационных системах применяются индивидуальные учетные записи, многофакторная аутентификация для критичных и удаленных доступов, журналирование значимых действий, резервное копирование и контроль актуальности программного обеспечения.

5.4. Выгрузки, таблицы и отчеты с ПДн маркируются, передаются по согласованным защищенным каналам и удаляются из временных мест после завершения задачи. Массовые выгрузки требуют отдельного согласования.

5.5. Бумажные носители хранятся в запираемых шкафах или помещениях. Определяются места хранения и лица с доступом. По окончании рабочего дня документы не оставляются на столах и в общедоступных зонах.

5.6. Удаленная работа с ПДн допускается только на управляемых устройствах и через одобренные каналы доступа. Локальное копирование и печать разрешаются лишь при подтвержденной необходимости.

5.7. Тестовые среды используют обезличенные или синтетические наборы. Применение продукционных ПДн допускается как исключение по согласованию с ответственным за ПДн и ИБ и при эквивалентных мерах защиты.

5.8. Жизненный цикл доступа

Этап	Контроль	Подтверждение
Запрос	Цель, роль, системы, срок, объем доступа	Заявка / распоряжение
Согласование	Руководитель + владелец системы/данных	Электронное согласование
Предоставление	Именная учетная запись, минимальные права	Запись в журнале
Контроль	Периодическая ревизия и анализ событий	Отчет о ревизии
Отзыв	В день прекращения необходимости, перевода или увольнения	Закрытая заявка / акт

→ 6. Передача, поручение и трансграничная передача

6.1. Предоставление ПДн третьему лицу допускается при наличии правового основания, в объеме, необходимом для конкретной цели, и после проверки получателя. Факт и параметры передачи должны быть воспроизводимы.

6.2. До поручения обработки Оператор оценивает надежность обработчика. В договоре или поручении указываются перечень ПДн и операций, цели, обязанность соблюдать конфиденциальность, требования статей 18.1 и 19 Закона № 152-ФЗ, меры защиты, обязанность подтверждать соблюдение требований и уведомлять об инцидентах.

6.3. Обработчик не вправе менять цели, привлекать субобработчика или передавать ПДн за пределы согласованной инфраструктуры без письменного разрешения Оператора. По окончании поручения данные возвращаются или уничтожаются с подтверждением.

6.4. Обмен по открытым каналам без соответствующей защиты запрещен. Получатель и вложение перепроверяются до отправки. Пароли к защищенным архивам передаются отдельным каналом.

6.5. До начала трансграничной передачи Оператор отдельно уведомляет Роскомнадзор в установленном порядке и проводит оценку иностранного получателя и государства назначения. Передача начинается только после выполнения требований закона и отсутствия запрета уполномоченного органа.

6.6. Реестр третьих лиц и трансграничных передач содержит получателя, страну, цель, состав данных, основание, договор, канал, срок, меры защиты, дату последней проверки и ответственного.

ПРАВИЛО МИНИМАЛЬНОЙ ПЕРЕДАЧИ

Получателю передается не весь имеющийся профиль субъекта, а только поля, необходимые для согласованной цели. Где возможно, используются обезличивание, псевдонимизация, агрегирование и ограничение периода выборки.

Проверка обработчика до договора

Блок	Что проверить
Правовой	Роль стороны, цель, основание, конфиденциальность, субобработчики, возврат/уничтожение.
Технический	Размещение данных, доступ, шифрование, журналы, резервные копии, управление уязвимостями.
Инциденты	Срок первичного уведомления Оператора, состав сообщения, контакты 24/7, участие в расследовании.
Контроль	Право запроса подтверждений и аудита, периодичность переоценки, ответственность.

→ 7. Права субъекта и обработка обращений

7.1. Субъект вправе получать сведения об обработке, требовать уточнения, блокирования или уничтожения ПДн, требовать прекращения обработки в предусмотренных законом случаях, отзываться согласие, возражать против прямого маркетинга и обжаловать действия Оператора.

7.2. Обращения принимаются по адресу и контактам из карточки Оператора. Личность и полномочия заявителя проверяются соразмерным способом; запрещается запрашивать избыточные данные или направлять ответ незащищенному получателю.

Событие	Срок по общему правилу	Действие
Запрос о наличии и обработке ПДн	10 рабочих дней; возможно продление не более чем на 5 рабочих дней с мотивированным уведомлением	Проверить личность, найти данные, согласовать и безопасно направить ответ
Подтверждение неточности	7 рабочих дней со дня предоставления сведений	Уточнить ПДн и снять блокирование
Неправомерная обработка	Прекратить не позднее 3 рабочих дней; если легализовать невозможно - уничтожить не позднее 10 рабочих дней	Заблокировать на период проверки, устранить нарушение, уведомить заинтересованных лиц
Требование прекратить обработку	10 рабочих дней; возможно продление не более чем на 5 рабочих дней с мотивированным уведомлением	Прекратить, если нет законного исключения; зафиксировать основание решения
Отзыв согласия	Прекратить и при отсутствии иного основания уничтожить не позднее 30 дней	Проверить иные основания, остановить связанные операции и рассылки
Достижение цели	Прекратить обработку и уничтожить не позднее 30 дней, если иное не предусмотрено законом или договором	Сформировать доказательство уничтожения

7.3. Маршрут обращения

7.3.1. Получатель регистрирует обращение в день поступления и немедленно передает ответственному за ПДн. В журнале фиксируются дата, заявитель, содержание, способ идентификации, исполнители, решение, сроки и дата ответа.

7.3.2. Ответственный координирует поиск по всем системам и обработчикам, проверяет правовые ограничения, готовит ответ понятным языком и контролирует безопасную доставку.

7.3.3. Отказ должен быть мотивированным и содержать ссылку на применимое основание. Копии материалов обращения и ответа хранятся по утвержденному сроку.

→ 8. Безопасность и реагирование на инциденты

8.1. Оператор определяет угрозы, уровень защищенности информационных систем ПДн и реализует необходимые правовые, организационные и технические меры с учетом характера обработки, актуальных угроз и возможного вреда субъектам.

Область	Минимальные меры
Управление	Назначение ответственных, реестр процессов и систем, оценка вреда, модель угроз, внутренний контроль, управление изменениями.
Доступ	Идентификация и аутентификация, минимальные права, MFA, разделение обязанностей, регулярная ревизия.
Инфраструктура	Сегментация, безопасная конфигурация, обновления, защита от вредоносного кода, резервирование, мониторинг.
Данные	Шифрование или эквивалентная защита, контроль копирования, маскирование, защита каналов, безопасное уничтожение.
Физическая защита	Контроль помещений, хранение носителей, учет выдачи, правило чистого стола, уничтожение бумажных документов.
Люди	Обязательства о конфиденциальности, вводный и ежегодный инструктаж, фишинг-тренировки, дисциплинарные процедуры.

8.2. Действия при инциденте

- 1 Обнаружить и сообщить: любой работник немедленно направляет сообщение на [КАНАЛ ИНЦИДЕНТОВ] и не предпринимает действий, уничтожающих следы.
- 2 Сдержать: команда ИБ изолирует затронутые учетные записи, устройства и каналы, сохраняя журналы и доказательства.
- 3 Оценить: определить состав ПДн, субъектов, системы, период, получателей, последствия и продолжающийся риск.
- 4 Уведомить: при инциденте, повлекшем неправомерную или случайную передачу, предоставление, распространение или доступ, направить первичное уведомление Роскомнадзору в течение 24 часов.
- 5 Расследовать: провести внутреннее расследование и в течение 72 часов сообщить его результаты и сведения о виновных лицах при их наличии.
- 6 Восстановить и улучшить: устранить причину, безопасно восстановить работу, оценить необходимость информирования субъектов и выполнить корректирующие меры.

КРИТИЧЕСКИЙ СРОК

24 и 72 часа отсчитываются с момента выявления инцидента Оператором. Внутреннее сообщение должно поступить ответственным незамедлительно, чтобы сохранить время на проверку и уведомление.

→ 9. Хранение, блокирование и уничтожение

9.1. Для каждой цели устанавливаются событие начала срока, продолжительность хранения, место хранения, формат, владелец и способ уничтожения. Сроки синхронизируются в бумажных и электронных системах, резервных копиях и у обработчиков.

9.2. По достижении цели, истечении срока, отзыве согласия при отсутствии иного основания, подтверждении неправомерности обработки или получении законного требования данные блокируются и уничтожаются в установленные сроки.

9.3. Блокирование должно исключать дальнейшее использование, кроме действий, необходимых для проверки, уточнения, исполнения закона или защиты прав. Статус и основание блокирования фиксируются в системе или журнале.

9.4. Уничтожение должно исключать восстановление содержания ПДн. Метод выбирается с учетом носителя: криптографическое стирание, гарантированное удаление, перезапись, физическое разрушение, шредирование или услуги проверенного подрядчика.

9.5. Подтверждение уничтожения оформляется по требованиям приказа Роскомнадзора № 179: актом об уничтожении и выгрузкой из журнала регистрации событий в информационной системе в применимых случаях. Подтверждающие документы хранятся три года с момента уничтожения, если иной срок не установлен законом.

9.6. Резервные копии учитываются в процедуре уничтожения. Если немедленное выборочное удаление технически невозможно, данные выводятся из активного использования и уничтожаются при плановой ротации копии в документированный срок.

9.7. Акт уничтожения должен позволять установить

1. Оператора и комиссию/ответственное лицо;
2. дату, место, основание и способ уничтожения;
3. категории субъектов, перечень или категории ПДн и носителей;
4. информационную систему и обработчика, если применимо;
5. период данных, количество носителей/записей и результат контроля;
6. подписи участников и реквизиты подтверждающей выгрузки.

ЗАПРЕТ

Удаление ярлыка, перемещение в корзину, форматирование без проверки, выбрасывание бумаги или носителя в обычный мусор не являются подтвержденным уничтожением ПДн.

→ 10. Контроль, обучение и ответственность

10.1. Руководитель Оператора назначает лицо, ответственное за организацию обработки ПДн. Оно подотчетно руководителю, получает необходимые полномочия и ресурсы, организует контроль и рассматривает обращения.

10.2. Владелец процесса отвечает за законность цели, минимизацию состава, актуальность реестра, соблюдение сроков и корректность передачи. ИТ и ИБ реализуют и подтверждают технические меры. Руководители подразделений контролируют доступ работников.

10.3. До допуска к ПДн работник знакомится с Регламентом и применимыми инструкциями под подпись или подтвержденным электронным способом. Повторное обучение проводится не реже одного раза в год и после существенных изменений.

10.4. Внутренний контроль проводится по риск-ориентированному плану, но не реже одного раза в год. Проверяются основания, согласия, уведомления, реестры, доступы, договоры, сроки хранения, журналы, инциденты и доказательства уничтожения.

10.5. Выявленные несоответствия регистрируются с владельцем, сроком и корректирующей мерой. Критические нарушения устраняются немедленно; до устранения процесс может быть приостановлен.

10.6. Лица, нарушившие требования, несут дисциплинарную, материальную, гражданско-правовую, административную или уголовную ответственность в порядке, предусмотренном законодательством и договорами.

10.7. Ежегодный пакет доказательств

Документ / запись	Ответственный	Периодичность
Реестр процессов и информационных систем	Ответственный за ПДн + владельцы	Постоянно / ежегодная сверка
Акт оценки вреда и модель угроз	ПДн / ИБ	При изменениях и по плану
Ревизия доступов	ИТ + владельцы систем	Не реже ежегодно, для критичных систем чаще
Журнал обращений и инцидентов	ПДн / ИБ	Постоянно
Реестр обработчиков и договоров	Юристы + закупки + ПДн	До договора и периодически
Обучение и ознакомление	HR + ПДн	При допуске и ежегодно
Акты уничтожения	Комиссия / владелец	По графику хранения

→ 11. Заключительные положения

11.1. Регламент вступает в силу с даты, установленной приказом об утверждении, и действует до отмены или замены новой редакцией.

11.2. Изменения вносятся приказом руководителя. Основания для внепланового пересмотра: изменение законодательства, целей или состава данных, запуск новых систем, привлечение нового обработчика, трансграничная передача, существенный инцидент или результаты проверки.

11.3. Если норма Регламента противоречит обязательному требованию законодательства, применяется законодательство, а ответственное лицо инициирует корректировку документа.

11.4. Действующая редакция хранится в [МЕСТО ХРАНЕНИЯ] и доступна всем допущенным работникам. Устаревшие версии архивируются с указанием срока действия.

11.5. Публичная политика Оператора не заменяет настоящий внутренний Регламент. На сайте публикуется документ, определяющий политику в отношении обработки ПДн, и сведения о реализуемых требованиях к защите в объеме, не раскрывающем конфиденциальные сведения о системе безопасности.

Роль	Должность / Ф.И.О.	Подпись	Дата
Разработал	[ДОЛЖНОСТЬ, Ф.И.О.]	_____	«__» ____ 20__
Согласовал	[ЮРИДИЧЕСКАЯ ФУНКЦИЯ]	_____	«__» ____ 20__
Согласовал	[ИНФОРМАЦИОННАЯ БЕЗОПАСНОСТЬ]	_____	«__» ____ 20__
Согласовал	[HR / ВЛАДЕЛЕЦ ПРОЦЕССА]	_____	«__» ____ 20__

ПЕРЕД УТВЕРЖДЕНИЕМ

Заполните реквизиты, удалите неприменимые цели, закрепите фактические сроки хранения, каналы обращений и инцидентов, перечень систем и обработчиков, после чего проведите юридическую и техническую проверку под реальные процессы Оператора.

→ Приложение 1. Матрица ролей

Роль	Ключевая ответственность
Руководитель Оператора	Утверждает политику и локальные акты, назначает ответственного, обеспечивает ресурсы, принимает решения по существенным рискам.
Ответственный за организацию обработки ПДн	Ведет методологию и реестры, контролирует соответствие, координирует обращения, уведомления, оценку вреда, обучение и проверки.
Владелец процесса	Определяет и обосновывает цель, состав, сроки, получателей; обеспечивает точность и выполнение процедур в подразделении.
Информационная безопасность	Определяет угрозы и меры защиты, мониторит события, реагирует на инциденты, сохраняет доказательства и участвует в расследовании.
ИТ	Администрирует системы и доступ, резервное копирование, обновления, журналирование, удаление и технические подтверждения.
Юридическая функция	Проверяет основания, формы согласий, договоры, поручения, трансграничную передачу, ответы и изменения законодательства.
HR	Организует законную обработку данных работников и кандидатов, ознакомление и прекращение доступов при кадровых изменениях.
Работник с доступом	Соблюдает цель и инструкции, обеспечивает конфиденциальность, не копирует данные без необходимости, сообщает об инцидентах.
Комиссия по уничтожению	Проверяет основание и состав, контролирует необратимое уничтожение, оформляет подтверждающие документы.

Минимальный маршрут согласования нового процесса

Шаг	Исполнитель	Результат
1. Описание	Владелец процесса	Карточка цели, данных, субъектов, систем, получателей, сроков
2. Правовая проверка	ПДн + юрист	Основание, уведомления, согласия, договорные условия
3. Оценка защиты	ИБ + ИТ	Угрозы, уровень защищенности, меры, размещение и доступ
4. Решение	Уполномоченные лица	Согласование, ограничения или отказ
5. Запуск и контроль	Владелец + ПДн	Запись в реестре, обучение, периодическая проверка

→ Приложение 2. Формы учетных записей

А. Журнал обращений субъектов

□ Регистрационный № / дата и время поступления:

□ Ф.И.О. субъекта или представителя; способ проверки полномочий:

□ Канал поступления и безопасный канал ответа:

□ Суть требования и затронутые цели/системы:

□ Исполнители и запросы обработчикам:

□ Контрольный срок; продление и мотивировка:

□ Решение, дата ответа, способ доставки:

□ Выполненные уточнение, блокирование, прекращение или уничтожение:

Б. Карточка инцидента

□ Дата/время выявления и источник сообщения:

□ Системы, категории ПДн и примерное число субъектов/записей:

□ Характер события и предполагаемые последствия:

□ Принятые меры сдерживания и сохраненные доказательства:

□ Решение о квалификации инцидента; ответственные лица:

□ Первичное уведомление Роскомнадзора: дата, время, идентификатор:

□ Результаты расследования; дополнительное уведомление в 72 часа:

□ Корректирующие меры, владельцы и сроки выполнения:

В. Карточка передачи третьему лицу

□ Получатель, роль и страна размещения:

□ Цель, основание, категории субъектов и перечень данных:

□ Договор/поручение, канал, периодичность и срок:

□ Субобработчики, трансграничность, локализация:

□ Оценка надежности, меры защиты и дата пересмотра:

→ Приложение 3. Контрольные источники

Документ подготовлен с учетом требований законодательства Российской Федерации по состоянию на 22 сентября 2026 года. Перед утверждением необходимо проверить специальные требования, применимые к отрасли и фактическим процессам Оператора.

Источник	Назначение
Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных»	Базовые принципы, основания, права субъектов, обязанности Оператора, безопасность, уведомления и сроки.
Постановление Правительства РФ от 01.11.2012 № 1119	Требования к защите ПДн при обработке в информационных системах.
Постановление Правительства РФ от 15.09.2008 № 687	Особенности обработки без использования средств автоматизации.
Приказ ФСТЭК России от 18.02.2013 № 21	Состав и содержание организационных и технических мер защиты.
Приказ Роскомнадзора от 27.10.2022 № 178	Требования к оценке вреда субъектам ПДн.
Приказ Роскомнадзора от 28.10.2022 № 179	Требования к подтверждению уничтожения ПДн.
Федеральный закон от 24.06.2025 № 156-ФЗ	Требование оформлять согласие на обработку ПДн отдельно от иных подтверждаемых или подписываемых документов с 01.09.2025.



ПОРТАЛ ПЕРСОНАЛЬНЫХ ДАННЫХ РОСКОМНАДЗОРА

Проверка уведомлений, формы и справочная информация:

<https://pd.rkn.gov.ru/>

Официальное опубликование правовых актов

<https://publication.pravo.gov.ru/>

КОНЕЦ ДОКУМЕНТА / ВЕРСИЯ 1.0 / 22.09.2026